Clase 321 — Comunicación y reporte para analistas de seguridad

> Parte: **17 — Profundización para certificaciones** · Fuente: *CompTIA CySA+ (CS0-003) — Reporting and Communication · (ISC)² CISSP OSG — Security Operations* ⏱️ Duración estimada: **120 min** · Nivel: **Intermedio**

🎯 Objetivo

Un hallazgo que nadie entiende no se remedia. Esta clase enseña a **comunicar y reportar** como analista de seguridad: escribir informes de vulnerabilidades e incidentes claros, adaptar el mensaje a la audiencia (técnica, gestión, ejecutiva, legal), definir **métricas y KPIs** que importan, y comunicar **durante** un incidente sin generar pánico ni filtrar información sensible. Es el dominio de *Reporting and Communication* de CySA+ (el de mayor peso conceptual en el examen) y una habilidad que define la carrera de un analista tanto como su capacidad técnica.

📚 Resultados de aprendizaje

Al finalizar, el alumno podrá:

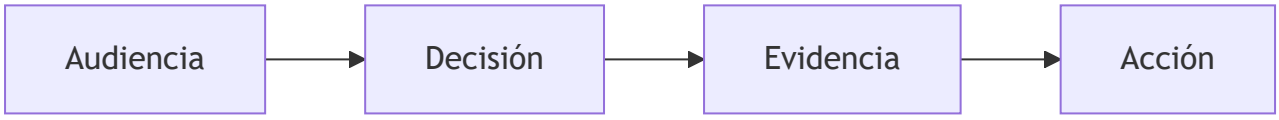
1. **Redactar** un informe de vulnerabilidades y uno de incidente con estructura estándar (resumen ejecutivo, hallazgos, evidencia, recomendaciones).
2. **Adaptar** un mismo hallazgo a tres audiencias: técnica, gestión y dirección ejecutiva.
3. **Definir** métricas de programa (MTTD, MTTR, cobertura, backlog de vulnerabilidades) con umbral y frecuencia.
4. **Aplicar** un plan de comunicación de crisis durante un incidente activo, con canales y escalado.
5. **Distinguir** obligaciones de notificación (interna, clientes, reguladores, fuerzas del orden) y sus plazos.

🗺️ Temas

#	Tema	Por qué importa
1	Anatomía de un informe de seguridad	Estructura reutilizable que todos entienden
2	Audiencia técnica vs gestión vs ejecutiva	El mismo dato exige tres traducciones
3	Resumen ejecutivo (BLUF)	La dirección decide en el primer párrafo
4	Métricas, KPIs y KRIs de SOC	Demuestran valor y priorizan trabajo
5	Comunicación durante un incidente	Coordina sin filtrar ni improvisar
6	Escalado y árbol de decisión	Quién se entera, cuándo y por qué canal
7	Notificaciones obligatorias y plazos	Cumplimiento legal (GDPR 72 h, etc.)
8	Lecciones aprendidas y reporte post-incidente	Cierra el ciclo y mejora el programa

🧠 Modelo mental y caso de decisión

El reporte adapta decisión, evidencia y lenguaje a audiencia sin ocultar incertidumbre ni exagerar impacto.



Caso razonado. Un ejecutivo necesita exposición y opciones; el anexo conserva comandos y hashes para ingeniería.

📓 Glosario operativo complementario

Término	Definición
Evidencia	Información cuya procedencia y relación con un criterio pueden revisarse.
Supuesto	Condición declarada de la que depende una conclusión.
Riesgo residual	Exposición que permanece después del tratamiento.

✅ Criterio de dominio

El alumno demuestra dominio cuando explica el diagrama, resuelve el caso con evidencia, declara límites y puede defender por qué su decisión cambia si cambia un supuesto.

Cómo lo nombra el catálogo CWE y qué cambia al priorizar

Un buen informe nombra la causa y mide con transparencia. Sobre lo primero, cuando un hallazgo técnico se redacta para otros equipos conviene acompañarlo de la **entrada del catálogo CWE** que lo describe (por ejemplo, `CWE-89` para una inyección SQL), porque es el lenguaje con el que los desarrolladores, las herramientas de análisis y las bases de datos de vulnerabilidades pueden agrupar y buscar. Sobre lo segundo, **toda cifra declara su procedencia**: versión y grupo de métricas de CVSS (CVSS-B v3.1, CVSS-BE

v4.0...), fuente del número (CNA, NVD, CISA-ADP, tu equipo) y fecha de consulta de los datos que cambian a diario (KEV, EPSS). Una cifra sin etiqueta no se puede comparar con otra, y las fuentes legítimas discrepan (clase 367).

El resumen ejecutivo es el sitio donde no van los identificadores crudos, pero sí las consecuencias que resultan de combinarlos: «dos activos expuestos tienen una vulnerabilidad con explotación confirmada y deben corregirse en tres días» es el resultado de leer CVE, KEV y exposición juntos (ver clase 369), no el número CVSS aislado. Las decisiones que se piden a dirección deben apoyarse en esas señales fechadas.

📖 Definiciones y características

- **BLUF (Bottom Line Up Front):** técnica de redacción que pone la conclusión y la acción requerida al principio. Característica clave: respeta el tiempo del lector ejecutivo, que decide antes de leer el detalle.
- **Resumen ejecutivo:** media página sin jerga que responde qué pasó, qué impacto tiene en el negocio y qué se pide decidir. Característica clave: se escribe **al final** pero se lee **primero**; no contiene comandos ni CVE crudos.
- **MTTD / MTTR:** *Mean Time To Detect* (tiempo medio hasta detectar) y *Mean Time To Respond/Remediate* (hasta responder/remediar). Característica clave: miden la eficacia operativa del SOC y son los KPIs que la dirección entiende.
- **KPI vs KRI:** un **KPI** mide desempeño pasado (% de activos escaneados); un **KRI** anticipa riesgo (nº de sistemas críticos sin parchear > SLA). Característica clave: se reportan juntos para dar foto y tendencia.
- **Stakeholder / audiencia:** grupo con interés en el reporte —analistas, dueños de sistema, gestión, dirección, legal, comunicación, reguladores. Característica clave: cada uno necesita distinto nivel de detalle y distinto vocabulario.
- **Canal fuera de banda (out-of-band):** medio de comunicación alterno (teléfono, Signal, sala física) usado durante un incidente por si el atacante controla el correo/chat corporativo. Característica clave: evita alertar al adversario y mantener la coordinación aunque el entorno esté comprometido.
- **Ventana de notificación:** plazo legal para notificar una brecha (p. ej. **72 horas** a la autoridad bajo GDPR). Característica clave: corre desde que se *conoce* la brecha, no desde que se resuelve.

🧰 Herramientas y preparación

Clase de comunicación; el "entorno" es documental y de plantillas:

- **Plantillas de informe** (procesador de textos o Markdown): estructura fija de portada, resumen ejecutivo, hallazgos, evidencia, recomendaciones, anexos.
- **Hoja de cálculo / dashboard** para métricas (MTTD, MTTR, backlog, cobertura) y su tendencia.
- **Matriz de escalado / árbol de llamadas** (call tree) con roles, no nombres, y canales primario y fuera de banda.
- **CVSS calculator** (FIRST.org) para justificar la severidad de cada hallazgo de forma objetiva.
- **Registro de comunicaciones** del incidente (timeline): hora, emisor, receptor, canal, mensaje —clave para el reporte post-incidente y para legal.

🧪 Laboratorio guiado — Redactar el paquete de reporte de un incidente

Ejercicio aplicado: a partir de un caso, produces el paquete completo de comunicación de un incidente de ransomware contenido.

1. **Toma el caso.** Escenario: EDR aísla tres estaciones tras detectar cifrado anómalo; se confirma ransomware en un segmento, sin exfiltración probada, contenido en 4 horas. Datos: activos afectados, hora de detección, hora de contención, acciones tomadas.
2. **Construye la línea de tiempo.** Tabla con hora, evento, actor y evidencia (ID de alerta EDR, hash, host). Es la columna vertebral de todo lo demás.
3. **Escribe el informe técnico.** Para el equipo: IOCs, hosts, técnica MITRE ATT&CK observada (p. ej. `T1486`), acciones de contención y erradicación, y recomendaciones concretas (parches, segmentación, backups).
4. **Redacta el resumen ejecutivo (BLUF).** Media página, sin jerga: qué ocurrió, impacto en el negocio (tres equipos parados 4 h, sin fuga confirmada), decisiones requeridas (aprobar reinstalación, revisar seguro), estado actual.
5. **Prepara el brief de gestión.** Nivel intermedio: riesgo residual, coste estimado de recuperación, SLA de vuelta a operación, y qué recursos se necesitan.
6. **Define el plan de comunicación.** Matriz de escalado: quién se entera a los 15 min, a la hora, y al cierre; canal primario y **fuera de banda**; qué se dice y qué **no** se dice mientras la investigación sigue abierta.
7. **Evalúa notificaciones obligatorias.** ¿Hay datos personales? ¿aplica GDPR/ley local? Documenta la decisión de notificar o no a reguladores/clientes y su justificación con marca temporal.
8. **Calcula las métricas.** MTTD y MTTR de este incidente; compáralos con el objetivo del SOC y anótalos en el dashboard de tendencia.
9. **Cierra con lecciones aprendidas.** 3–5 mejoras accionables con dueño y fecha, alimentando el programa (no un documento que se archiva).

Entregable: paquete con línea de tiempo, informe técnico, resumen ejecutivo, brief de gestión, plan de comunicación/escalado, decisión de notificación y cuadro de métricas.

✍️ Ejercicios

1. Reescribe un hallazgo técnico ("SMBv1 habilitado en 40 hosts, CVE-2017-0144") en una frase para dirección ejecutiva.
2. Redacta un resumen ejecutivo (máx. 150 palabras) para el incidente del laboratorio.
3. Diseña la matriz de escalado de tu organización (roles, canal primario, canal fuera de banda, umbral de tiempo).
4. Define cinco KPIs de SOC con umbral y frecuencia, y justifica por qué cada uno importa a la dirección.
5. Construye un árbol de decisión de notificación (interna → clientes → reguladores → fuerzas del orden) con los disparadores de cada rama.
6. Convierte un informe de vulnerabilidades de 20 hallazgos en un cuadro priorizado de "top 5 a remediar esta semana" con criterio explícito.

📝 Reto verificable

Reto: entrega el paquete de comunicación completo del incidente del laboratorio, apto para presentarlo en una reunión de crisis.

Criterio de aceptación:

- El **resumen ejecutivo** ocupa ≤ 1 página, no contiene jerga técnica ni CVE crudos y termina con las decisiones requeridas.
- El **informe técnico** incluye línea de tiempo con evidencia verificable, técnica MITRE ATT&CK y recomendaciones accionables con dueño.
- Existe una **matriz de escalado** con canal fuera de banda y umbrales de tiempo por rol.
- La **decisión de notificación** está documentada con su base legal y marca temporal (aunque la conclusión sea "no aplica").
- Se reportan **MTTD y MTTR** comparados con el objetivo y al menos tres lecciones aprendidas con dueño y fecha.

⚠️ Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"La dirección no entendió mi informe"	Escribiste para técnicos. Añade un resumen ejecutivo BLUF sin jerga y traduce el impacto a negocio.
"Reporté 200 vulnerabilidades y no pasó nada"	Sin priorización no hay acción. Entrega un top priorizado con criterio (CVSS+explotación+exposición).
"Durante el incidente todos preguntaban lo mismo"	Falta plan de comunicación. Define quién informa, a quién, cuándo y por qué canal.
"Usamos el correo corporativo y el atacante lo leía"	No usaste canal fuera de banda. Ten un medio alterno predefinido para incidentes.
"Nos pasamos del plazo de notificación"	El reloj corre desde que se *conoce* la brecha. Evalúa la obligación desde el minuto uno.
"Mis métricas no dicen nada"	Reportas cantidades sin tendencia ni objetivo. Añade umbral, comparación temporal y contexto.

❓ Preguntas frecuentes

❓ **¿Qué va y qué no va en un resumen ejecutivo?** Va: qué pasó, impacto en el negocio, estado actual y qué se pide decidir. No va: comandos, CVE crudos, nombres de herramientas ni detalle forense. Si un directivo no técnico no lo entiende en 60 segundos, reescríbelo.

❓ **¿Debo notificar siempre una brecha a los clientes o al regulador?** Depende del tipo de dato, jurisdicción y umbral de riesgo. Muchas leyes (GDPR) exigen notificar a la autoridad en 72 h si hay riesgo para las personas. Documenta siempre la decisión y su base legal, incluso cuando decidas que no aplica.

❓ **¿Cuáles son las métricas mínimas de un SOC?** MTTD, MTTR, cobertura de detección, backlog de vulnerabilidades/alertas y tasa de falsos positivos. Reportadas con objetivo y tendencia, no como número suelto.

❓ **¿Por qué separar comunicación técnica y ejecutiva si es el mismo incidente?** Porque persiguen decisiones distintas: el técnico necesita IOCs para actuar; el ejecutivo necesita impacto y opciones para decidir. Un solo documento para ambos falla con los dos.

🔗 Referencias

- CompTIA. *CySA+ (CS0-003) Exam Objectives* — dominio *Reporting and Communication*.
- Chapple, Stewart & Gibson. *(ISC)² CISSP Official Study Guide*, 9.ª ed., Sybex — Security Operations / Incident Management.
- NIST. *Computer Security Incident Handling Guide* — SP 800-61 Rev.2.
- FIRST. *CVSS v3.1 Specification & Calculator* — first.org/cvss.
- SANS. *Incident Handler's Handbook* — plantillas y comunicación de incidentes.

📥 Material descargable

- 📄 Guía en PDF — versión imprimible de esta clase.
- 🎞️ Presentación (PPTX) — deck para proyectar en clase.

⬅️ Clase anterior

Clase 320 — Gobierno, aspectos legales/regulatorios y gestión del programa

➡️ Siguiente clase

Clase 322 — Threat intelligence operacional avanzada